CITEF CYBER RANGE

ATTACK SCENARIO DESIGN DOCUMENT

Threat Actor: Scattered Spider (UNC3944)

Social Engineering • Identity Compromise • Ransomware Deployment

Document Type	Scenario Design Document v1.0
Prepared For	University of Ottawa, Cyber Range Team
Prepared By	Capstone Team: Netstrike
Supervisors	Prof. Timothy Lethbridge, Prof. Garzon
Course	Software Engineering Capstone
Date	April 2026
Classification	Academic / Internal Use Only

1. Executive Summary

This document details the complete attack scenario design for the University of Ottawa Capstone Project in partnership with the CITEF Cyber Range team. The scenario models a realistic multi-phasic intrusion campaign from Scattered Spider (also known as UNC3944, Octo Tempest, and Muddled Libra), one of the most documented and active financially driven threat actor groups.

The scenario is intended to be implemented in the current CITEF environment as a working proof-of-concept. Furthermore, it is designed to be reusable and portable for the purpose of integration into the Cyber Range team's forthcoming generation of CITEF platforms. It encompasses the complete attack kill chain from open-source reconnaissance, helpdesk impersonation, credential theft, and MFA bypass to lateral movement in a hybrid on-premises and cloud environment, and concluding with data exfiltration and the deployment of ransomware.

This project provides an attack simulation suite (a software repository with modular, scripted attack design phases) and a detection and evaluation framework that links each of the simulated techniques to the MITRE ATT&CK Enterprise Framework. The combination of offensive simulation and defensive tooling represents the primary software engineering component of the capstone project.

2. Threat Actor Profile: Scattered Spider

2.1 Overview

Also Known As	UNC3944 • Octo Tempest • Muddled Libra • Roasted 0ktapus • Storm-0875
Origin	English-speaking, primarily US and UK based
Active Since	May 2022
Motivation	Financial: data extortion, ransomware-as-a-service (RaaS) affiliate
Primary Targets	Hospitality, aviation, retail, insurance, telecommunications, finance
Notable Victims	MGM Resorts, Caesars Entertainment, M&S, Qantas, Twilio, Visa, Truist Bank
Ransomware Partners	ALPHV/BlackCat (2023), RansomHub (2024), DragonForce (2025, unconfirmed)
Government Advisories	CISA/FBI Joint Advisory AA23-320A (updated June 2025); MITRE ATT&CK G1015

2.2 Threat Actor Characteristics

Scattered Spider is identified by a number of features that set it apart among nation-state APT groups and render it both highly dangerous and at the same time manageable to simulate in academic settings:

- No zero-days required: They use social engineering, tools publicly available, and abuse of legitimate software to carry on with their attacks instead of writing their own exploits. This allows them to be simulated in the lab and still have their TTPs without having actual vulnerabilities.
- Native English fluency: Their impersonation attacks in the helpdesk are very real since the operators are native speakers of English and have studied the Western corporate culture at the core level.
- Rapid execution: The group is associated with finishing complete kill chains, including initial phishing and deployment of domain-wide ransomware, in 24-48 hours after initial access.
- Cloud-native attackers: This is one of the limited categories of cybercriminals that regularly shift between on-premises infrastructure to cloud infrastructure (AWS, Azure, Okta, Salesforce), which is a current hybrid-environment threat.
- Well-documented TTPs: CISA documented their techniques, as did the FBI, MITRE, and Mandiant/Google, and their techniques are a good source of material on academic simulation.

2.3 Real-World Incidents Informing This Scenario

The following Scattered Spider incidents have been reported and confirmed, and outline the scenario.

- MGM Resorts (September 2023): Initial access through LinkedIn OSINT and a helpdesk vishing call lasting 10 minutes. Resulted in over 100 million dollars in losses, deployment of ESXi ransomware, and several weeks of operational standstill.
- Caesars Entertainment (August 2023): Same TTPs; Caesars has a 15 million dollar ransom. Confirmed techniques of SIM swapping and MFA fatigue.
- MITRE ATT&CK Enterprise Evaluation 2025: Scattered Spider is one of the two threat actors selected by MITRE for their 2025 evaluation in the attack cover from on-premises to fully cloud.
- CISA Advisory AA23-320A (June 2025 update): The latest and most detailed technical outline of Scattered Spider TTPs to MITRE ATT&CK, spanning 14 tactic categories.

3. Scenario Overview

3.1 Scenario Summary

Scenario Name	Operation Silent Spider
Threat Actor	Scattered Spider (UNC3944)
Target Organization	SimCorp: a simulated mid-sized financial services firm (fictitious)
Environment	CITEF hybrid environment: on-premises Active Directory + simulated cloud (AWS/Okta)
Attack Objective	Data exfiltration of customer PII + ransomware deployment on ESXi infrastructure
Scenario Duration	Simulated over 48 hours of attack timeline (compressed for exercise execution)
Exercise Roles	Red Team (attack simulation), Blue Team (detection & response), Observer/Evaluator
MITRE Coverage	14 tactic categories, 30+ techniques

3.2 Target Environment Architecture

Simulated target organization (SimCorp) is set up like a real mid-sized enterprise, and is a fictitious financial services company, with the following infrastructure:

- On-premises: Windows Active Directory domain, employee workstations, internal file servers, VMware ESXi hypervisor cluster
- Identity: Okta SSO federated with Active Directory; MFA via Okta Verify push notifications
- Cloud: AWS environment with customer database (S3), internal applications (EC2), and CRM data
- Communication: Microsoft 365 (email, Teams), internal helpdesk ticketing system
- Public exposure: corporate LinkedIn with employee names, titles, and the organization structure

3.3 Attacker Objectives (Flags)

The attacker objectives and each corresponding simulation milestone and detection assessment point are outlined as follows:

- Flag 1 - Reconnaissance Complete: Attacker has profiled a legitimate helpdesk employee and IT admin target via OSINT
- Flag 2 - Initial Access: Attacker has gained access to legitimate credentials via phishing or credential buy simulation
- Flag 3 - MFA Bypassed: Attacker has successfully bypassed an account’s target MFA
- Flag 4 - Lateral Movement: Attacker has moved from the first compromised account to a domain admin

- Flag 5 - Cloud Pivot: Attacker has accessed the AWS environment with pilfered cloud credentials
- Flag 6 - Exfiltration: Attacker has extracted simulated customer PII from cloud
- Flag 7 - Ransomware Deployed: Attacker has deployed a ransomware payload on an ESXi cluster

4. Attack Kill Chain: Phase-by-Phase

Phase 1: Reconnaissance

MITRE Tactic: Reconnaissance (TA0043) • OSINT / Pre-Attack Information Gathering

The attacker does reconnaissance without making any direct contact with the target network.

What the Attacker Does

- Search LinkedIn for SimCorp employees (IT helpdesk, administrators, executives)
- Extract email address patterns from public profiles and job postings
- Identify Single Sign-On system (SSO) provider (Okta) through job listings mentioning "Okta administrator" requirements
- Collect helpdesk phone number from company website
- Develop social engineering pretext: impersonate senior employee experiencing account lockout while traveling

Simulation Implementation

- We create fake LinkedIn profiles in our test environment
- Our tool automatically pulls names, job titles, email patterns, and phone numbers
- Generates structured target profile JSON for next phase input

Phase 2: Initial Access – Phishing Infrastructure

MITRE Tactic: Initial Access (TA0001) • T1566 Phishing • T1598 Spearphishing for Information

Before or during the vishing call, the attacker sets up a fake login page to steal credentials. This attack runs after or at the same time as the phone attack.

What the Attacker Does

- Registers a lookalike domain (e.g. simcorp-okta[.]net) that's close enough to the real thing to deceive a stressed out employee
- Hosts a convincing fake Okta login page on that domain that silently captures any credentials entered

- Sends a phishing SMS or email asking the target to "re-authenticate" that's scheduled to hit alongside the vishing call.

Simulation Implementation

- The Phishing Infrastructure Module deploys a lightweight fake Okta login page within the CITEF isolated network
- A backend logger captures everything submitted (usernames, passwords, and session tokens).
- An automated employee agent visits the page and submits test credentials, simulating a real victim falling for the trap.

Phase 3: Helpdesk Vishing: Identity Takeover

MITRE Tactic: Initial Access / Credential Access • T1598.004 Spearphishing Voice • T1078 Valid Accounts

This is Scattered Spider's main signature technique. The attacker calls the corporate helpdesk, impersonates a senior employee and socially engineers a password reset and MFA removal for the targeted account.

What the Attacker Does

- Calls the help desk impersonating a senior employee, saying something like "I'm ___, VP of Finance and I'm travelling in London and completely locked out. I have a board call in 20 minutes."
- Backs up the story with details for research ex.employee ID, manager's name, last known login location.
- Pressures the helpdesk agent into resetting the password and temporarily removing MFA.
- Walks away with access to the account under attacker-controlled credentials.

Simulation Implementation

- In the live cyber range exercise, this phase is role-played in real time. One team member calls a designated helpdesk operator who plays the defender.
- The Vishing Script Generator tool builds a realistic call script on the fly, populated with OSINT data collected in Phase 1

Phase 4: MFA Bypass: Push Bombing

MITRE Tactic: Credential Access (TA0006) • T1621 MFA Request Generation • T1556 Modify Authentication Process

If the helpdesk does not disable MFA, the attacker uses MFA fatigue (push bombing). MFA fatigue sends requests to the target's phone with authentication requests until they accidentally approve one, or calling the target directly and tricking them into approving.

What the Attacker Does

- They attempt to login with stolen credentials repeatedly. This triggers a flood of Okta Verify push notifications to the target's device
- Simultaneously calls the target: 'Hi, this is IT support. You'll receive an Okta push in a moment, please approve it to complete a security update.'
- Target approves the push which lets the attacker into a valid authenticated session.

Simulation Implementation

- The MFA Fatigue Simulator sends repeated authentication requests against the simulated Okta environment.
- A simulated user agent is configured with a probability-based model that approves a push after N attempts (simulating fatigue).
- The module logs all push events with timestamps for detection evaluation.

Phase 5: Discovery & Lateral Movement

MITRE Tactics: Discovery (TA0007) • Lateral Movement (TA0008) • T1069, T1087, T1021, T1550

With a valid session established, the attacker maps the environment and works toward domain admin and cloud console access.

What the Attacker Does

- Enumerates Active Directory: user accounts, groups, privileged accounts, and computer objects using built-in Windows tools (net user, dsquery)
- Identifies domain admin accounts and their associated workstations
- Uses Pass-the-Hash or token replay to escalate from standard user to domain admin without re-entering credentials
- Accesses the VMware vCenter console using harvested credentials
- Pivots to Okta admin console and AWS management console using cloud credentials found after scanning the system

Simulation Implementation

- The Lateral Movement Engine executes a scripted sequence of AD enumeration commands within the CITEF Windows environment
- Privilege escalation is simulated using pre-staged credentials at each tier, triggered by the orchestrator
- All commands and their outputs are logged for detection scoring

Phase 6: Cloud Pivot & Data Exfiltration

MITRE Tactics: Collection (TA0009) • Exfiltration (TA0010) • T1530, T1537, T1567, T1048

The attacker uses harvested cloud credentials to access the AWS environment and exfiltrate simulated customer PII data from S3 storage, replicating the Scattered Spider data theft model.

What the Attacker Does

- Authenticates to AWS using IAM credentials found in emails or configuration files on compromised workstations
- Creates a new IAM backdoor user for persistence
- Enumerates S3 buckets and identifies the customer database bucket
- Exfiltrates data via AWS CLI commands, routing through TOR/VPN proxies to simulate operational security
- Prepares an extortion demand referencing the stolen data

Simulation Implementation

- A simulated AWS-equivalent environment within CITEF is pre-populated with synthetic customer PII records
- The Cloud Exfiltration Module executes the S3 enumeration and download sequence using AWS CLI against the simulated environment
- Exfiltrated data volume and timing are logged for detection evaluation

Phase 7: Ransomware Deployment

MITRE Tactics: Impact (TA0040) • T1486 Data Encrypted for Impact • T1490 Inhibit System Recovery

The final phase replicates Scattered Spider's use of RaaS partners (ALPHV/BlackCat, RansomHub) to deploy ransomware across the ESXi hypervisor infrastructure, maximizing operational impact.

What the Attacker Does

- Accesses VMware vCenter using domain admin credentials
- Deploys a simulated ransomware payload targeting ESXi virtual machine image files (.vmdk)
- Disables VSS shadow copies and backup jobs to prevent recovery
- Drops ransom note files across encrypted systems

Simulation Implementation

- A harmless file-encryption simulator that will use AES on decoy files only is deployed on specific CITEF VMs
- The payload mimics the file extension changes and ransom note format of RansomHub that's been documented in public reporting
- Recovery of files is prevented by deleting pre-staged simulated backup files

5. MITRE ATT&CK Technique Mapping

The table below maps every simulated technique to the MITRE ATT&CK Enterprise framework (v17). This mapping is used as the basis for detection scoring in the evaluation framework.

Phase	Tactic	Technique ID	Description
Phase 1	Reconnaissance	T1593.001	Search Open Websites/Domains: LinkedIn OSINT
Phase 1	Reconnaissance	T1589.002	Gather Victim Identity Info: Email addresses
Phase 1	Reconnaissance	T1598.003	Phishing for Information: Target profiling
Phase 2	Initial Access	T1566.002	Spearphishing Link: Fake Okta login page
Phase 2	Initial Access	T1660	Smishing: SMS/Email-based phishing link
Phase 2	Initial Access	T1597.002	Purchase Technical Data: Credential marketplace sim
Phase 3	Initial Access	T1598.004	Spearphishing Voice (Vishing): Helpdesk impersonation
Phase 3	Credential Access	T1078	Valid Accounts: Socially engineered password reset
Phase 4	Credential Access	T1621	MFA Request Generation: Push bombing
Phase 4	Credential Access	T1556	Modify Authentication Process: MFA removal
Phase 5	Discovery	T1069	Permission Groups Discovery: AD group enumeration
Phase 5	Discovery	T1087	Account Discovery: Domain user enumeration
Phase 5	Lateral Movement	T1021	Remote Services: RDP / WMI lateral movement
Phase 5	Lateral Movement	T1550	Use Alternate Authentication: Pass-the-Hash / token replay
Phase 5	Persistence	T1136	Create Account: Backdoor IAM user creation
Phase 6	Collection	T1530	Data from Cloud Storage: S3 bucket enumeration
Phase 6	Exfiltration	T1537	Transfer Data to Cloud Account: AWS CLI exfil
Phase 6	Exfiltration	T1567	Exfiltration Over Web Service: TOR-proxied transfer
Phase 7	Impact	T1486	Data Encrypted for Impact: ESXi ransomware
Phase 7	Impact	T1490	Inhibit System Recovery: VSS/backup deletion

6. Software Repository & Deliverables

6.1 Repository Structure

The repository is organized into various modules corresponding to each phase of the simulation with its own configuration, execution scripts, and test suite. Each module will be supported by a CI/CD pipeline and automated testing to ensure that each one follows a similar coding style. A top-level orchestrator combined with detection and dashboard components tie the modules together into a runnable end-to-end scenario.

Proposed repository layout:

```
operation-silent-spider/
    ├── modules/
    │   ├── 01-osint-profiler/         # Phase 1: OSINT automation
    │   ├── 02-phishing-infra/         # Phase 2: Credential capture page
    │   ├── 03-vishing-scripts/        # Phase 3: Social engineering toolkit
    │   ├── 04-mfa-fatigue-sim/        # Phase 4: Push bombing simulator
    │   ├── 05-lateral-movement/       # Phase 5: AD enumeration & escalation
    │   ├── 06-cloud-exfil/            # Phase 6: Cloud data exfiltration
    │   └── 07-ransomware-sim/         # Phase 7: Benign encryption payload
    ├── orchestrator/               # Scenario runner & flag tracker
    ├── detection/                  # Log ingestion, alerting, MITRE tagging
    ├── dashboard/                  # React-based exercise monitoring UI
    ├── citef-config/               # CITEF environment setup scripts
    ├── docs/                       # This document + technical references
    └── tests/                      # Unit and integration tests per module
```

6.2 Software Components

Component	Description	Phase	Technology
OSINT Profiler	Automated tool that scrapes a simulated employee directory and builds a structured target profile (name, email, title, phone, manager)	Phase 1	Python
Phishing Infra Module	Web app serving a fake Okta SSO login page that can log and capture entered credentials	Phase 2	Python
Vishing Script Generator	Automatically generates context-aware social engineering phone call scripts populated with OSINT data from Phase 1	Phase 3	Python / Jinja2
MFA Fatigue Simulator	Sends configurable bursts of MFA push notifications to simulated Okta and logs the timing of any MFA approvals	Phase 4	Python
Lateral Movement Engine	Scripted AD enumeration and privilege escalation targeting CITEF Windows environment	Phase 5	Python / PowerShell
Cloud Exfil Module	AWS CLI-based S3 enumeration and data download against simulated cloud environment	Phase 6	Python / AWS CLI
Ransomware Simulator	Harmless AES file encryptor targeting decoy file sets on designated VMs and displays a message based on the RansomHub note format	Phase 7	Python

Component	Description	Phase	Technology
Scenario Orchestrator	End-to-end runner that executes modules, tracks flags, logs events, and produces scenario execution reports	All Phases	Python
Detection Dashboard	Real-time web UI displaying attack events, MITRE technique tags, and detection status for blue team evaluation	Detection Layer	React / FastAPI
Log Analyzer	Ingests CITEF system logs and applies detection rules mapped to MITRE ATT&CK techniques; outputs scored alerts	Detection Layer	Python

6.3 Detection & Evaluation Framework

Each software module logs events in a standard JSON schema. The Log Analyzer ingests these events and applies a set of detection rules, each tagged with the corresponding MITRE ATT&CK technique. Then, the Detection Dashboard displays real-time scoring for the blue team, showing which techniques were detected, missed, or incorrectly alerted.

Evaluation metrics collected:

- Detection Rate per phase: percentage of simulated attack techniques that were detected
- False Positive Rate: alerts triggered on benign baseline traffic during the simulation
- Time-to-Detect (TTD): elapsed time between technique execution and alert generation
- MITRE Coverage Score: number of ATT&CK techniques covered by at least one detection rule
- Portability Score: percentage of modules that execute successfully in the new cyber range environment without modification

7. In-Person Cyber Range Exercise Design

7.1 Exercise Format

The scenario is designed to support a live in-person exercise on the CITEF cyber range, structured as a red team vs. blue team engagement with an observer/evaluator role for the capstone team and academic supervisors.

Exercise Duration	Half-day (4 hours) or full-day (8 hours) format, configurable
Injects	Vishing call (Phase 3) executed live; all other phases via software modules
Scoring	Automated via Detection Dashboard; manual observer scoring for vishing phase

7.2 Exercise Phases & Timeline

The following is a compressed exercise timeline for a 4-hour format:

- Hour 0:00 – 0:15 : Briefing: scenario context, rules of engagement, tool access confirmed
- Hour 0:15 – 0:30 : Phase 1 (Reconnaissance): OSINT Profiler executed, target profile generated
- Hour 0:30 – 0:50 : Phase 2 (Phishing): Phishing page deployed, employee credential capture step simulated
- Hour 0:50 – 1:10 : Phase 3 (Vishing): Live helpdesk impersonation call; outcome logged
- Hour 1:10 – 1:30 : Phase 4 (MFA Bypass): Repeated notification push executed against simulated Okta
- Hour 1:30 – 2:00 : Phase 5 (Lateral Movement): AD enumeration, privilege escalation, cloud pivot setup
- Hour 2:00 – 2:30 : Phase 6 (Exfiltration): Cloud data exfiltration executed and logged
- Hour 2:30 – 3:00 : Phase 7 (Ransomware): Encryption payload deployed on designated decoy VMs
- Hour 3:00 – 3:30 : Blue Team Response: Defenders attempt detection, containment, and recovery
- Hour 3:30 – 4:00 : Debrief: Detection Dashboard review, scoring, lessons learned discussion

7.3 CITEF Environment Requirements

The following infrastructure components are required within CITEF to execute this scenario:

- Windows Active Directory domain (at minimum: 1 domain controller, 3 workstations, 1 file server)

- VMware ESXi host with at least 2 guest VMs (targets for ransomware simulation phase)
- Simulated Okta SSO environment with MFA push simulation capability
- Simulated AWS environment (LocalStack or equivalent) containing generated PII
- Isolated network with full packet capture enabled for post-exercise log analysis
- Simulated employee directory (web-accessible, mimicking LinkedIn/corporate intranet)
- Helpdesk ticketing interface accessible to blue team defenders

8. Portability & Integration with New Cyber Range Platform

A primary objective of this capstone is to produce scenario artifacts that are portable beyond the current CITEF environment and can be integrated into the Cyber Range team's next-generation platform. The following design principles are applied throughout the software implementation to support this goal:

- Containerization: All attack modules are packaged as Docker containers with documented environment variables, enabling deployment on any infrastructure capable of running containers
- Configuration-driven: Target hostnames, credentials, and environment parameters are externalized into YAML configuration files rather than hardcoded, allowing the same modules to run against different range configurations
- Standard event schema: All module logs emit events in a common JSON schema aligned with STIX 2.1 observable objects, enabling integration with any SIEM or exercise management platform
- MITRE ATT&CK tagging: Every emitted event includes the corresponding ATT&CK technique ID, enabling detection coverage mapping regardless of the platform consuming the logs
- Documented API: The Scenario Orchestrator exposes a REST API for starting, stopping, and querying scenario state, enabling integration with the new cyber range's exercise management system

9. Limitations & Ethical Boundaries

The following constraints apply to this scenario to ensure it operates safely within an academic and controlled environment:

- All attack modules operate exclusively within the isolated CITEF network. No traffic leaves the cyber range environment.
- The ransomware simulator uses a benign AES encryption routine applied only to pre-staged decoy files on designated VMs. No real system files, operating system components, or student data are targeted.
- No real social engineering is conducted against real individuals. The vishing phase targets a designated exercise participant who has consented to the role.

- No real credentials, real cloud accounts, or real organizational infrastructure are used at any point.
- The phishing infrastructure module is deployed only within the CITEF isolated network and is not accessible from the public internet.
- All scenario artifacts, logs, and synthetic data are stored within the university's controlled environment and handled in accordance with University of Ottawa data governance policies.

10. References & Sources

- CISA/FBI Joint Cybersecurity Advisory AA23-320A: Scattered Spider (updated June 2025). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a
- MITRE ATT&CK Group G1015: Scattered Spider. https://attack.mitre.org/groups/G1015/
- MITRE ATT&CK Enterprise Evaluation 2025: Scattered Spider / GOLD HARVEST scenario. Sophos blog, December 2025.
- Picus Security: Tracking Scattered Spider Through Identity Attacks and Token Theft, July 2025.
- Obsidian Security: Scattered Spider SaaS Attack Analysis & MITRE ATT&CK Mapping, November 2025.
- Google Threat Intelligence Group (GTIG): Defending Against UNC3944 / Scattered Spider.
- GuidePoint Security: Worldwide Web – Analysis of Tactics and Techniques Attributed to Scattered Spider, June 2024.
- Barricade Cyber Solutions: CTI Report – Scattered Spider Threat Actor Group, May 2025.
- IC3/FBI FLASH: Scattered Spider Advisory (updated July 2025). https://www.ic3.gov/CSA/2025/250729.pdf